DESIGNING A SECURE SYSTEM ARCHITECTURE

PayLink Africa Fintech — Online payment and Digital wallet platform

ARCHITECTURE DESIGN

Overview

> **Internet Tier**
> Banking Partners, Card Users, Web and Mobile App clients, Employees

> **Public Edge**
> WAF, DDOS Protection

> **DMZ**
> Edge Firewall, API gateway, IDS/IPS, VPN gateway

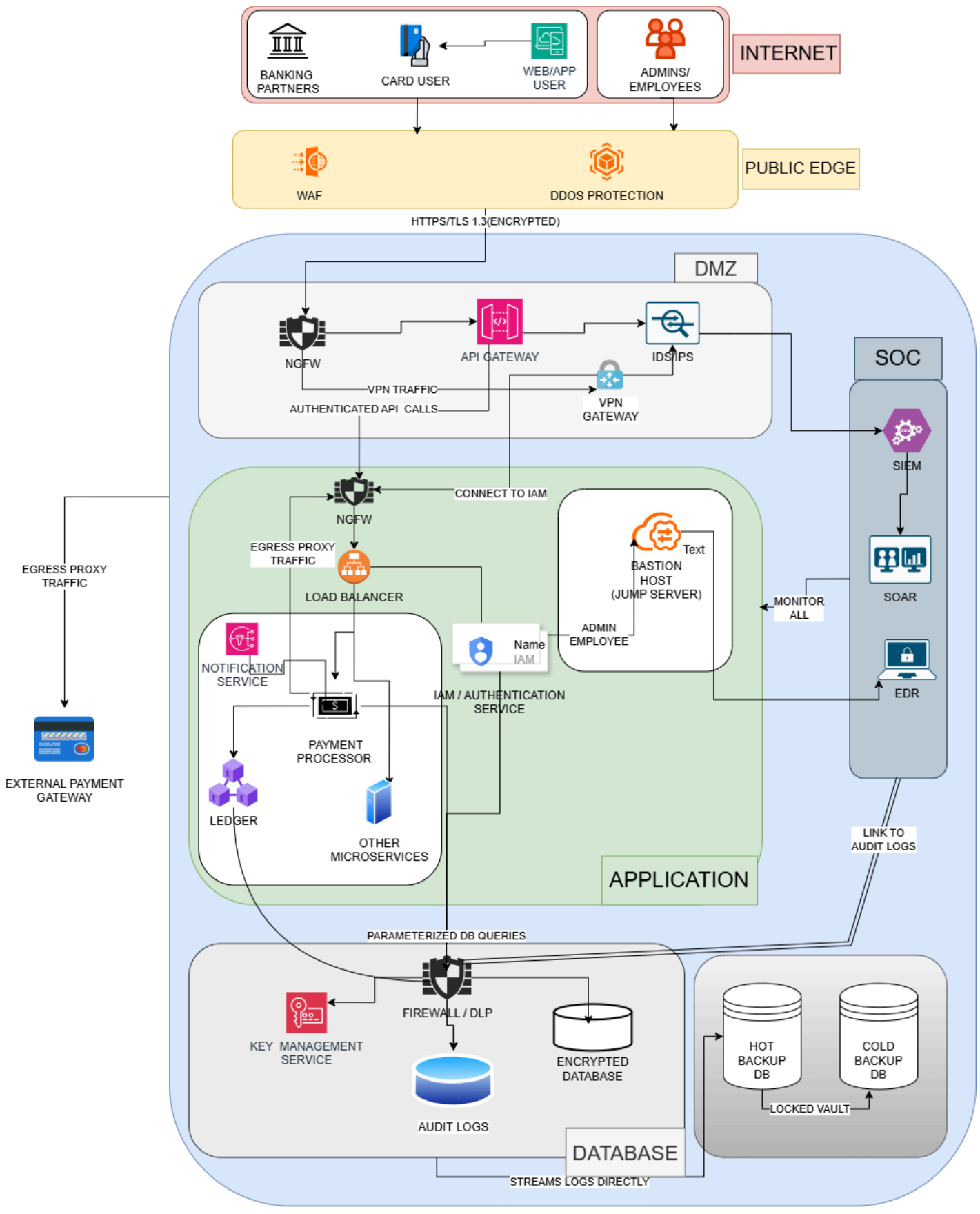
> **Application Tier**
> Internal NG Firewall, Load balancer, IAM, Web server(Payment Processor, Ledger, Notification service, Other Microservices), Jump Server

> **Database Tier**
> Key Vault, Primary Encrypted DB(Audit logs, Encrypted DB), Hot Backup, Cold Backup)

> **Security Operations (SOC) Tier**
> SIEM, SOAR, EDR

> **External Payment Gateway**
> Connects to external payment networks like Mastercard, Visa, or regional banks (Interswitch).

Architecture Diagram



Security Controls Mapping:

- **Access control and authentication:** Centralized IAM in the Application Tier handles merchant/user authentication (OAuth 2.0). Administrative access requires an IPsec VPN, multi-factor authentication (MFA), and routing through a heavily monitored Bastion Host.
- **Encryption:** All data in transit from the client to the database is secured via TLS 1.3. Sensitive data at rest (card numbers, PII) in the Database Tier and its backups are encrypted using AES-256.
- **Backup and disaster recovery:** A synchronized read replica resides within the Database Tier, with encrypted snapshots routinely sent to an off-site, immutable disaster recovery location to ensure business continuity.
- **Monitoring and logging:** SIEM, SOAR and EDR (like Wazuh) is deployed centrally, with agents installed across the DMZ, App, and Database tiers for File Integrity Monitoring (FIM), real-time threat detection, and unified log aggregation.
- **Risk management measures:** Strict network segmentation isolates the database. Vulnerability scanning, penetration testing routines, and a dedicated secrets vault for managing API keys mitigate risks. Defense-in-depth reduces the risk of a breach.

Explanation and Justification

Introduction and Framework Alignment

The architectural design for PayLink Africa is fundamentally driven by the **SABSA (Sherwood Applied Business Security Architecture)** framework. Unlike purely technical frameworks, SABSA ensures that security services are directly derived from business requirements. For a fintech company, the primary business drivers are customer trust, regulatory compliance (such as PCI DSS), and high availability for uninterrupted payment processing. By following SABSA's top-down approach, this architecture translates the business need for "secure and reliable transactions" into specific logical network segments and physical security appliances (Logical and Physical layers), ensuring every security control provides direct business value.

Enforcing the CIA Triad

The foundation of this architecture rests on maintaining Confidentiality, Integrity, and Availability;

- **Confidentiality** is enforced rigorously to protect sensitive cardholder data and PII. Network traffic is encrypted in transit using TLS 1.3, preventing eavesdropping on public or internal networks. At rest, data within the isolated Database Tier is encrypted using AES-256. Access to this data is governed strictly by Role-Based Access Control (RBAC), ensuring only authorized microservices and authenticated users can view specific data segments.
- **Integrity** guarantees that financial transactions remain accurate and unaltered. We achieve this through cryptographic hashing (HMAC) of API requests, ensuring payloads are not modified between the merchant and the API gateway. Furthermore, File Integrity Monitoring (FIM) via our SIEM actively monitors host servers for unauthorized changes to critical application binaries or configuration files, preventing silent tampering.
- **Availability** ensures the payment platform remains operational, a core business requirement. The architecture incorporates redundancy at every level: cloud-based DDoS protection absorbs volumetric attacks at the edge, internal load balancers distribute traffic across multiple application servers, and a synchronized database replica allows for rapid failover in a disaster scenario.

Defense in Depth and Least Privilege

To combat sophisticated adversaries, the architecture employs **Defense in Depth,** layering independent controls so that the failure of one does not compromise the entire system. An external attacker targeting customer data must first bypass the WAF, evade the IDS/IPS in the DMZ, compromise an application server, and somehow defeat the internal NGFW and database-level encryption.

Simultaneously, the **Principle of Least Privilege** dictates the flow of traffic and user permissions. Systems and users are granted only the minimum access necessary to perform their functions. The API gateway in the DMZ have absolutely no direct route to the database; they can only forward validated requests to the Application Tier. Administrators cannot connect directly to production servers; they must authenticate through a VPN and a Bastion Host, creating a deliberate, heavily monitored network for privileged access.

Threat Mitigation Strategies

This architecture specifically addresses high-impact risks to the fintech sector:

1. **Injection Attacks (SQLi / XSS):** Merchants and users constantly send data to the platform, creating injection vectors. This threat is mitigated primarily at the edge by the WAF, which identifies and drops malicious HTTP payloads. As a secondary defense, the Application Tier enforces strict input validation and relies exclusively on parameterized queries, ensuring that even if a payload bypasses the WAF, it cannot be executed by the database.
2. **Distributed Denial of Service (DDoS):** A successful DDoS attack would violate our availability. By utilizing cloud edge DDoS scrubbing, volumetric attacks are absorbed before they reach the PayLink infrastructure. Rate-limiting at the API Gateway further protects against application-layer (Layer 7) resource exhaustion.
3. **Insider Threat / Compromised Administrator:** A rogue employee or an attacker with stolen admin credentials poses a massive risk to data confidentiality. This is mitigated through strict network segmentation and centralized logging. Even with valid credentials, lateral movement is restricted by internal firewalls. The Wazuh SIEM continuously analyzes administrator behavior, immediately triggering alerts for anomalous activities, such as bulk data exports or unauthorized database access outside of normal maintenance windows. Simultaneously, the SOAR automatically takes action if anomalous activities are detected.

Reflection

What was the hardest part of designing your architecture?

The most difficult challenge was balancing the rigorous security required for financial transactions with the low-latency performance demanded by an online payment gateway. Applying the SABSA framework highlighted the tension between the business need for speed and the security need for thorough inspection. If security controls are too heavy, transaction timeouts increase, leading to merchant dissatisfaction; if they are too light, the organization faces unacceptable regulatory and financial risks.

How would your design differ if the company operated entirely in the cloud (AWS, Azure, or GCP)?

If PayLink Africa transitioned to a fully cloud-native environment like AWS, the logical architecture would remain similar, but the physical implementation would change drastically. Physical firewalls and routers would be replaced by AWS VPCs, Security Groups, and Network ACLs for micro-segmentation. Edge protection would utilize AWS Shield and AWS WAF. Instead of managing a standalone database cluster, I would leverage Amazon RDS with Multi-AZ deployments for native, automated high availability. Furthermore, Identity and Access Management (IAM) would become the primary security boundary, tightly controlling the execution of serverless functions (like AWS Lambda) and access to storage.

What lessons did you learn about balancing security, cost, and usability?

I learned that It is impossible and financially irresponsible to secure every asset to the maximum degree. Over-securing an environment leads to massive operational costs and creates friction that actively degrades usability for legitimate customers. The key is classifying data accurately and applying the most robust, expensive controls (like database firewalls and hardware security modules) exclusively to the most important assets (cardholder data), while utilizing efficient, scalable controls for less sensitive components.